



**Instituto Tecnológico y de Estudios Superiores de Monterrey
Campus Monterrey**

Escuela de Ingeniería y Ciencias

Ingeniería en Ciencias de Datos y Matemáticas

Uso de álgebras modernas para seguridad y criptografía, MA2006B.604

Reporte Ejecutivo - Etapa 1: Gestor de Identidades

Equipo 2:

Ana Lidia Hernández Díaz	A00838643
Ana Paula García Valverde	A01174572
María Fernanda Montoya López	A01743214
Javier Rojas Orrante	A01352213
Xavier Lago Hicks	A01403177

Profesores:

Raúl Gómez Anas Wajid Alberto F. Martínez

*Proyecto: Firmas Solidarias – Tecnología Criptográfica para los Derechos Humanos
Socio Formador: Casa Monarca*

Monterrey, Nuevo León. 30 de abril de 2026

Índice

1. Introducción	2
2. Contexto	2
3. Objetivo principal	2
4. Objetivos específicos	2
5. Arquitectura técnica	3
6. Modelo de los datos	4
7. Roles del sistema	4
8. Modelo de autenticación	5
9. Autorización y acceso por rol	5
10. Alta de usuarios	5
11. Activación y reactivación	5
12. Revocación	6
13. Expiración de cuentas	6
14. Cambio de rol	6
15. Certificados digitales y clave privada	7
16. Recuperación del administrador	7
17. Auditoría y trazabilidad	8
18. Valor para Casa Monarca y fortalezas	8
19. Conclusión	8

1. Introducción

El proyecto consiste en dar una solución a Casa Monarca mediante la cual se pueda fortalecer la seguridad y control interno de la organización, por lo que se desarrollo una aplicación que funciona como un gestor de identidades y accesos en la que se puedan administrar los usuarios y los permisos que tiene cada usuario mediante roles y permisos por rol, esta solución asegura que cada usuario de la aplicación tenga sus permisos definidos y solo pueda acceder a las funciones que corresponden a su rol previamente definido. La aplicación utiliza FastAPI para el manejo de la interfaz web y las rutas, SQLAlchemy para la persistencia de datos, SQLite para almacenar los datos, y la librería cryptography para los certificados, y la firma del administrador. Esta aplicación nos muestra como la organización podría gestionar a sus usuarios de manera segura, trazable, y controlada. La aplicación asegura todo esto asignando permisos específicos según el tipo de usuario, todo esto siendo estipulado por el administrador, Esta manera que tiene la aplicación de gestionar a los usuarios evita que se permitan accesos indebidos de usuarios reduciendo el riesgo de un problema operativo.

2. Contexto

Casa Monarca al ser una organización que maneja información sensible, es evidente que no todos los usuarios puedan acceder y manipular la información, por lo que Casa Monarca necesita una sistema que le permita gestionar estos usuarios y controlar quien puede acceder a que, y quien puede manipular la información de Casa Monarca, por esto nos enfocamos en un gestor que organice los roles y accesos de los usuarios. Se busca crear una herramienta a Casa Monarca que sea segura y amigable al momento de utilizarla, que incluya los elementos esenciales para un gestor de identidad, como la creación de usuarios, asignación de roles, revocación y reactivación de usuarios, expiración de permisos, trazabilidad por medio de auditoria, y una recuperación del perfil del administrador en caso de un inconveniente.

3. Objetivo principal

Nuestro objetivo es desarrollar e implementar una aplicación que funcione como gestor que permita a la organización administrar los usuarios de Casa Monarca, tanto beneficiarios como colaboradores, controlando sus accesos y permisos mediante roles y credenciales. Se busca que cada usuario tenga un rol relacionado a permisos por cada rol con un mecanismo de autenticación por medio de herramientas criptográficas y ademas que las acciones realizadas por ciertos colaboradores queden registradas en una bitácora para poder realizar una auditoria con fines de revisión y trazabilidad de las acciones realizadas por los colaboradores.

4. Objetivos específicos

- Sistema de alta y administración de usuarios
- Asignación de roles
- Control de acceso según los permisos asignados a cada rol en especifico
- Autenticación de usuarios
- Revocación o activación de accesos por parte del administrador
- Registro de movimientos importantes en una bitácora
- Mecanismo de recuperación de la cuenta del administrador

- Uso de certificados digitales

5. Arquitectura técnica

La aplicación está definida como una aplicación web local, la estructura esta definida como módulos que dividen:

- La interfaz: Que es lo que el usuario ve en la pantalla
- Lógica de la aplicación: Donde estas las reglas
- Base de datos: Donde se guarda toda la información, como usuarios, roles, permisos, etc
- Modelos de salida de la API: Los formatos de salida para que el usuario reciba respuesta por parte de la aplicación

En el archivo main.py es donde se corre el sistema, incluye:

- FastAPI: Al levantar FastAPI en el archivo main, permite que la aplicación funcione en la web
- Rutas web: Son los link internos de la aplicación, cada link te lleva a otra pagina de la aplicación
- Login: Donde el usuario inicia sesión
- Dashboard administrativo: Pantalla principal del administrador, donde tiene el control del gestor, es decir, donde se administra todo lo relacionado con los usuarios
- Portales por rol: Son los diferentes portales que se muestran a cada usuario dependiendo su rol
- Rutas de exportación de reportes: Son las funciones que permiten que se descarguen los reportes en PDF

En el archivo services.py es donde esta la lógica de la aplicación, donde se encuentran las reglas que hacen que la aplicación funcione de manera correcta, incluye:

- Auditoria: Se registran las acciones realizadas en la aplicación, como por ejemplo la creación de un usuario
- Contraseñas: Se protegen, verifican y almacenan las contraseñas, las contraseñas se guardan como hashes para su protección
- Autorización: Cuando un usuario quiere realizar una acción, se verifica si su rol lo permite realizar esa acción
- Expiración: Detecta si la cuenta de un usuario sigue vigente o ya expiro
- Recuperación: Si el administrador pierde acceso o no esta disponible para acceder, se recupera la cuenta por medio de la cuenta espejo del administrador
- Login por contraseña: Valida los accesos de usuarios operativos o voluntarios
- Login por firma: Valida los accesos del administrador o los coordinadores usando certificados
- Creación de usuario: Lógica para dar de alta un usuario
- Certificados: Se maneja la validación y emisión de certificados
- Datos iniciales: Se cargan los datos como roles, permisos o usuarios cuando se arranca la aplicación.

La aplicación puede generar reportes PDF que incluyan información administrativa como podrían ser listas de usuarios, o movimientos importantes realizados. Para garantizar una verificación de integridad en estos reportes PDF, se calcula un hash SHA-256 generado a partir de los datos incluidos en el reporte, así para que si se manipula el reporte, el hash ya no coincida con el reporte manipulado.

6. Modelo de los datos

Los datos son representados en una tabla en la que se muestra lo necesario para administrar la identidad y acceso de cada usuario, los campos funcionales que se encuentran en la tabla de datos de usuarios son:

- Correo electrónico
- Nombre completo
- Rol
- Estado
- Contraseña cifrada
- Fecha de expiración

Ademas de guardar información de los usuarios, el sistema también guarda información relacionada con los certificado, importantes para hacer el acceso mas seguro para cuentas de colaboradores o la del administrador, estos campos son:

- Numero de serie de certificado
- Certificado en formato PEM
- Fecha de vigencia
- Archivo .p12

Los diferentes estados que puede tener una cuenta son:

- Pending: El usuario ha sido creado, pero todavía no puede acceder a la aplicación
- Active: El usuario puede acceder a la aplicación
- Revoked: El acceso del usuario fue revocado, por lo que no puede acceder
- Expired: La cuenta del usuario ya venció

7. Roles del sistema

El sistema maneja cuatro tipos de roles:

- Admin: Es el rol con mas poder, puede hacer prácticamente todo, puede crear cuentas, activarlas, revocarlas, cambiar roles, realizar auditorias, manejar los certificados, activar la cuenta espejo, básicamente puede hacer todo. Además su acceso es con .p12 que es un método muy seguro de acceso.
- Coordinador: Es el segundo rol con mas poder, tiene una vista amplia de la información y puede trabajar con ella, pero no puede administrar a los usuarios como lo hace el administrador, este rol también tiene su acceso con .p12 con el admin.
- Operativo: Es el tercero con mas poder, tiene funciones limitadas y entra con su usuario y contraseña.
- Voluntario: Este es el rol con menos poder en el sistema, tiene un acceso muy limitado y también entra con su usuario y contraseña

Aquí se aplica el principio de mínimo privilegio, ya que se le da el permiso y acceso justo y necesario a cada usuario para que pueda realizar sus cometidos, es decir no se le da poder de mas a nadie que no sea necesario.

8. Modelo de autenticación

Al ser los roles Admin y Coordinador los de mayor jerarquía en el sistema, sus cuentas necesitan más seguridad, por lo que su autenticación es mas fuerte, ellos no solamente con una contraseña, sino que utilizan un archivo .p12 y la contraseña del archivo, este archivo .p12 es una llave digital que básicamente contiene información criptográfica, que es su certificado y su clave privada, y con esto se valida que son ellos quienes están accediendo a su cuenta, es básicamente una protección extra de seguridad.

Los roles de Operativo y Voluntario al no ser tan importantes, no necesitan esa fuerza en la verificación, por lo que ellos solamente entran con su usuario y contraseña, y la contraseña esta protegida con un hash para mayor seguridad.

9. Autorización y acceso por rol

El sistema controla lo que puede hacer cada usuario después de iniciar sesión:

- Autorización por roles: Por medio de AuthorizationService el sistema puede verificar que puede verificar que puede hacer cada usuario, se combina recurso con acción, recurso puede ser por ejemplo, “auditoria”, “certificados”, “usuarios”, etc, y acción puede ser por ejemplo, “crear”, “ver”, “modificar”, etc. Y si esta combinación de recurso con acción esta permitida para cierto rol, la acción se permite, de lo contrario no.

10. Alta de usuarios

El proceso de alta de usuarios en la aplicación asegura que el nuevo acceso de usuarios sea seguro, controlado y trazable, asegurando el principio de mínimo privilegio, funciona de la siguiente manera:

- Creación del usuario: El administrador puede crear un usuario desde su interfaz, completando los campos de nombre completo, correo electrónico, rol, y fecha de expiración. También alguien puede solicitar acceso en la interfaz de login al seleccionar solicitar acceso y llenar los campos de nombre completo, correo electrónico, y contraseña. Cuando se crea un usuario, ya sea creado por el administrador, o desde la pagina web, la cuenta del usuario queda en estado pending, esto significa que todavía no puede acceder a su cuenta, y tiene que esperar a que el administrador active la cuenta.
- Asignación de rol y permisos: Cuando se crea el usuario, se le asigna un rol por parte del administrador.
- Autenticación y credenciales: Al crearse el usuario, si es de el administrador o colaborador, se le asigna un certificado criptográfico que necesitara para iniciar sesión posteriormente, si el rol es de operador o voluntario, su inicio de sesión sera unicamente con su usuario y contraseña.

11. Activación y reactivación

La activación y reactivación de usuarios por parte del administrador permiten que exista mayor control sobre quien tiene acceso a la aplicación, dejando que solamente usuarios verificados puedan tener acceso, esto evita problemas de seguridad derivados de accesos no autorizados y que todos los permisos sean correctos y trazables.

- Los usuarios nuevos, ya sean creados por el administrador o por el usuario personalmente, quedan en pending hasta que el admin los active

- El admin activa los usuarios cambiando el estado a active
- Los usuarios que fueron revocados o expirados pueden ser reactivados por el administrador, solamente no si es el perfil de un colaborador o administrador en el que la cuenta esta ligada a un certificado, aquí se tendría que hacer una nueva cuenta para generar un nuevo certificado.
- Todos estos cambios de estado quedan registrados en la bitácora de auditoria

Todo esto permite que solamente los usuarios autorizados por el administrador puedan tener acceso, garantizando la seguridad.

12. Revocación

Ante situaciones criticas, el administrador puede bloquear cuentas de manera inmediata para garantizar que una cuenta a que estaba haciendo algo indebido ya no tenga acceso a la información sensible de Casa Monarca

- El administrador puede revocar una cuenta de manera instantánea en caso de riesgo
- Al cambiar de rol a Revoked, la cuenta queda bloqueada automáticamente
- Estas revocación quedan registrada en la bitácora de auditoria
- Al tener un apartado de notificaciones, se puede ver en tiempo real cuando una cuenta fue revocada, esto para mayor control sobre lo que esta pasando dentro del sistema en tiempo real

Esta revocación es indispensable para que ante cualquier riesgo coincidente se pueda actuar rápido y eliminar cualquier acceso no deseado en tiempo real.

13. Expiración de cuentas

Las cuentas tienen una fecha de expiración, al llegar a esta fecha de expiración la cuenta queda inhabilitada, esto es de gran ayuda para que solamente usuarios activos y vigentes tengan acceso a la aplicación, así manteniendo la seguridad, y evitando la acumulación de cuentas antiguas en el sistema.

- Todos los usuarios tienen una fecha de expiración ligada a su cuenta
- Al llegar a esta fecha de expiración, la cuenta pasa al estado Expired, inhabilitando automáticamente la cuenta, similar a si hubiera sido revocada.
- Este sistema de expiración permite que se den accesos temporales a diferentes usuarios en casos como podrían ser voluntarios o proyectos.
- Esta expiración también queda registrada en la bitácora de auditoria

14. Cambio de rol

El administrador tiene el poder de cambiar el rol a un usuario, esto es posible debido a que existe la evolución en cuanto a responsabilidad de usuarios, y se les pueda cambiar su rol si que tengan que crear otra cuenta.

- El administrador es capaz de cambiar el rol de cualquier usuario en cualquier momento

- Aplicando el principio del mínimo privilegio, al cambiar de rol un usuario, automáticamente se cambian sus permisos también
- Todos los cambios de rol realizados queden registrados en la bitácora
- Esta función de cambio de rol, permite que el sistema se adapte a los cambios de equipo o funciones manteniendo el control de todo

15. Certificados digitales y clave privada

Para aumentar la seguridad de la aplicación se incluyen certificados digitales que refuerzan la autenticación para perfiles de administrador y colaboradores.

- Los administradores y coordinadores utilizan certificados .p12 al momento de iniciar sesión, estos archivos contienen una clave privacidad y un certificado publico.
- La clave privada se borra en el momento en el que se descarga, esto para asegurar que no se pueda filtrar, dejando solamente una clave privada que no se puede recuperar.
- En caso de que esta clave privada se pierda, se tendrá que crear otra cuenta del colaborador o administrador para generar otra clave privada
- El certificado publico si queda guardado en la base de datos
- Esta clave privada y certificado se validan al momento de que el administrador y colaborador inician sesión verificando su identidad y así evitando accesos indebidos
- Los usuarios con rol de operativo y voluntario, no tienen esta clave privada ni certificado, ya que sus roles no son tan importantes, estos roles acceden con su usuario y contraseña, esta contraseña esta protegida con un hash en la base de datos, para que este segura

16. Recuperación del administrador

Si el administrador no se encuentra disponible o pierde acceso a su cuenta, la aplicación tiene un mecanismo para la recuperación de la cuenta de administrador y se asegura la continuidad operativa ante un inconveniente de este tipo.

- La cuenta del administrador puede ser recuperada por medio del mecanismo espejo de la aplicación
- Funciona básicamente como una cuenta espejo del administrador que esta inactiva, pero se puede activar en caso de que la cuenta principal sea inaccesible
- Permite la recuperación de la cuenta sin comprometer la seguridad del sistema
- Este proceso también es registrado en la bitácora

Este mecanismo asegura que Casa Monarca tenga protegida su administración de manera segura y controlada ante cualquier inconveniente

17. Auditoría y trazabilidad

Para mantener la transparencia en la aplicación, cada movimiento realizado dentro del sistema queda registrado en la bitácora

- La creación, activación, revocación, cambios de rol, certificados, y generación de PDF quedan registrados dentro de la bitácora
- Los registros incluyen fecha, hora, y quien realizo la acción
- Es importante al momento de realizar auditorias de manera confiable
- Facilita detectar las causas de algún problema al momento de un incidente

Esta auditoria refuerza la seguridad operativa al permitir trazar las acciones realizadas dentro de la aplicación.

18. Valor para Casa Monarca y fortalezas

La aplicación realizada aporta un valor a Casa Monarca de manera que los permite tener un control centralizado y seguro sobre sus usuarios, asignando roles y aplicando herramientas criptográficas para volver todo mas seguro, así aumentando su eficiencia operativa y reduciendo riesgos que puedan llegar a afectar la información sensible que manejan, ademas de esto la aplicación es sencilla y amigable de utilizar para el usuario Puntos clave y fortalezas del sistema:

- Gestión de roles y permisos de manera segura
- Uso de hash en las contraseñas y certificados digitales para la protección de cuentas
- Mecanismos de recuperación ante inconvenientes
- Reportes generados con hash para asegurar que no fueron manipulados
- Evita errores humanos y accesos indebidos
- Facilita revisiones internas por medio de auditorias
- Reduce carga administrativa al automatizar la gestión de identidades
- Protege las cuentas de usuarios de alto rango por medio de certificados digitales y ofrece una autenticación segura

La aplicación aporta seguridad, eficiencia y confiabilidad a los procesos de Casa Monarca y refuerza el control y protección de su información sensible.

19. Conclusión

Consideramos que la implementación de esta aplicación a la operación de Casa Monarca puede representar una avance en su seguridad y control interno de su organización al facilitar, automatizar, y reforzar la seguridad en el campo de gestión de identidades. Esta aplicación ayuda a la seguridad de Casa Monarca ya que gracias a la definición clara de los roles, autenticación reforzada con certificados digitales, contraseñas protegidas con hash, trazabilidad de acciones por medio de auditoria, y la facilitación de procesos como la creación, activación, revocación, y expiración de cuentas se asegura que unicamente los usuarios autorizados por un administrador tengan

acceso a la información que maneja Casa Monarca dependiendo sus funciones en la organización. Englobando los beneficios de la aplicación podemos concluir que aplicar este sistema a Casa Monarca fortalece la confianza dentro de sus procesos internos, y garantiza la seguridad de su información.